Conceptos de Seguridad en Redes

- Introducción
- Estado Actual de la Ciberseguridad
- Agentes de Amenazas
- Herramientas de los Agentes de Amenazas
- Malware
- Ataques de Red Habituales
- Vulnerabilidades y Amenazas de IP
- Mejores Prácticas en Seguridad de Redes
- Criptografía
- Resumen

1

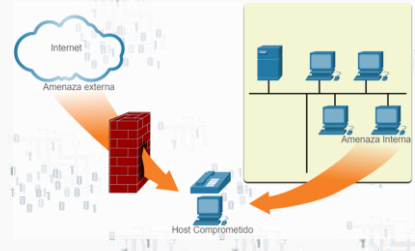
Introducción

- Este capítulo explica cómo mitigar vulnerabilidades, amenazas y ataques para mejorar la seguridad de la red.
- Describe:
  - Estado actual de la ciberseguridad y vectores de pérdida de datos.
  - Herramientas que utilizan los hackers para explotar redes.
  - Tipos de malware y ataques de red habituales.
- Explica:
  - Cómo los hackers explotan vulnerabilidades de tipo IP, así como vulnerabilidades de tipo TCP y UDP.
  - Cómo los hackers explotan servicios IP.
- Describe:
  - Las mejores prácticas para proteger una red.
  - Los procesos criptográficos comunes utilizados para proteger datos en tránsito.

2

Estado Actual de la Ciberseguridad

- Los hackers están llevando los ataques a niveles de sofisticación e impacto sin precedentes, volviéndose más expertos en el uso de técnicas para ocultar su actividad y explotando brechas de seguridad.
- Las infracciones pueden resultar en pérdida de ingresos para empresas, robo de propiedad intelectual, demandas judiciales o amenazas para la seguridad pública.
- Mantener la red garantiza la seguridad de los usuarios y protege los intereses comerciales.
- Vector de ataque:
  - Vía o método por el cual un actor de amenaza puede obtener acceso a un servidor, host o red.
  - Se originan dentro o fuera de la red corporativa.



3

Estado Actual de la Ciberseguridad

- Un usuario interno (e.g., empleado) puede de manera accidental o intencional:
  - Robar y copiar datos confidenciales.
  - Comprometer servidores internos o dispositivos de infraestructura de red.
  - Desconectar una conexión crítica y provocar interrupción de la red.
  - Conectar una unidad USB infectada a un sistema.
- Las amenazas internas tienen mayor potencial para causar daños que las amenazas externas porque los usuarios tienen acceso directo al edificio y sus dispositivos:
  - También tienen conocimiento de la red, recursos, datos confidenciales y privilegios administrativos.
- Los profesionales de seguridad deben:
  - Implementar herramientas y aplicar técnicas para mitigar amenazas externas e internas.

4

Estado Actual de la Ciberseguridad

- Los datos suelen ser el activo más valioso de una organización:
  - Relacionados con I+D, ventas, finanzas, recursos humanos, asuntos legales, empleados, contratistas y clientes.
- La pérdida de datos puede generar:
  - Daño de la marca/pérdida de la reputación
  - Pérdida de la ventaja competitiva
  - Pérdida de clientes
  - Pérdida de ingresos
  - Acciones legales que generen multas y sanciones civiles
  - Costo/esfuerzo significativos para notificar a las partes afectadas y recuperarse de la infracción
- Vectores de pérdida de datos comunes:
  - Información confidencial en correo o redes sociales
  - Dispositivos de almacenamiento no encriptados
  - Acceso comprometido a dispositivos de la nube
  - Medios extraíbles no autorizados o extraviados
  - Borrado de datos no necesarios en respaldos físicos
  - Contraseñas débiles

5

Agentes de Amenazas

- El término actor de amenaza incluye hackers, pero también dispositivos, personas, grupos o estados que, intencionalmente o no, sea la fuente de un ataque.

Tipo de Hacker	Descripción
Hackers de Sombrero Blanco	Hackers éticos que utilizan habilidades de programación para fines buenos, éticos y legales. Informan de vulnerabilidades a desarrolladores para corregirlas antes de que puedan explotarse.
Hackers de Sombrero Gris	Personas que cometen delitos y otras cosas poco éticas, pero no para beneficio personal ni para causar daños. Pueden divulgar una vulnerabilidad de una organización después de haber puesto en peligro la red.
Hackers de sombrero negro	Delincuentes poco éticos que violan la seguridad de una computadora y una red para beneficio personal o por motivos maliciosos.

6

Agentes de Amenazas

- El hacking comenzó en los 60s con el "phone freaking", actividad que hace referencia al uso de diversas frecuencias de audio para manipular sistemas telefónicos:
  - La marcación por tonos se usaba para realizar funciones.
  - Imitar tonos servía para atacar sistemas telefónicos y hacer llamadas de larga distancia gratis.
- A mediados de los 80s, se usaban módems de acceso telefónico para conectar computadoras a las redes:
  - Los hackers escribieron programas que marcaban números de teléfono en un área en busca de computadoras.
  - Cuando se encontraba un módem, se utilizaban programas que descifraban contraseñas para obtener acceso.
- Actualmente, los cibercriminales apuntan a pequeñas empresas y consumidores, así como grandes empresas e industrias:
  - Operan en una economía clandestina donde compran, venden e intercambian herramientas, códigos y servicios.
  - También compran/venden información privada y propiedad intelectual robada a sus víctimas.

7

Agentes de Amenazas

Término de piratería	Descripción
Script kiddies	Adolescentes o hackers inexpertos que ejecutan scripts, herramientas y exploits para ocasionar daño, pero generalmente no para obtener ganancias
Agentes de vulnerabilidad	Generalmente hackers que intentan descubrir exploits e informarlos a los proveedores a cambio de premios o recompensas
Hacktivistas	Hackers que protestan contra organizaciones o gobiernos mediante la publicación de artículos, vídeos, filtración de información confidencial y ejecución de ataques a la red
Delincuentes cibernéticos	Hackers de sombrero negro independientes que trabajan para grandes organizaciones de delito cibernético
Patrocinados por el estado	Hackers que roban secretos de gobierno, recopilan inteligencia y sabotean redes. Sus objetivos son gobiernos, grupos terroristas y empresas

8

Herramientas de los Agentes de Amenazas

▪ Para validar la seguridad, se han desarrollado herramientas de prueba para penetración de red.

Herramientas	Descripción
Decodificadores de contraseñas	Conocidas como herramientas de recuperación de contraseña. Hacen intentos repetidos para averiguar contraseñas (e.g., John the Ripper, Ophcrack, LOphtCrack, THC Hydra, RainbowCrack y Medusa)
Hacking inalámbrico	Para hackear intencionalmente una red inalámbrica con el fin de detectar vulnerabilidades (e.g., Aircrack-ng, Kismet, InSSIDer, KisMAC, Firesheep y ViStumbler)
Escaneo de redes y hacking	Sondear dispositivos de red, servidores y hosts con puertos TCP o UDP abiertos (e.g., Nmap, SuperScan, Angry IP Scanner y NetScanTools)
Elaborar paquetes de prueba	Sondear y probar la solidez de un firewall usando paquetes especialmente diseñados (e.g., Hping, Scapy, Socat, Yersinia, Netcat, Nping y Nemesis)
Analizadores de protocolos de paquetes	Capturar y analizar paquetes dentro de redes tradicionales LAN Ethernet o WLAN (e.g., Wireshark, Tcpdump, Ettercap, Dsniff, EtherApe, Paros, Fiddler, Ratproxy y SSLstrip)

9

Herramientas de los Agentes de Amenazas

Herramientas	Descripción
Detectores de rootkits	Comprobador de integridad de archivos y directorios utilizado por hackers de sombrero blanco para detectar malware instalado (e.g., AIDE, Netfilter y OpenBSD Packet Filter)
Fuzzers para buscar vulnerabilidades	Usada con el objetivo de provocar comportamientos inesperados o errores en una computadora que podrían ser explotados por atacantes (e.g., Skipfish, Wapiti y W3af)
Informática forense	Utilizadas por hackers de sombrero blanco para detectar cualquier rastro de evidencia existente en una computadora (e.g., Sleuth Kit, Helix, Maltego y Encase)
Depuradores	Usado por hackers de sombrero negro para aplicar ingeniería inversa en archivos binarios cuando programan ataques. También las utilizan los sombreros blancos cuando analizan malware (e.g., GDB, WinDbg, IDA Pro e Immunity Debugger)
OS para hacking	Sistemas operativos especialmente diseñados con herramientas optimizadas para hacking (e.g., Kali Linux, BackBox Linux)
Cifrado	Utilizan algoritmos para codificar los datos y prevenir el acceso no autorizado (e.g., VeraCrypt, CipherShed, OpenSSH, OpenSSL, Tor, OpenVPN y Stunnel)
Atacar vulnerabilidades	Identifican si un host remoto es vulnerable a un ataque de seguridad (e.g., Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit y Netsparker)
Escáneres de vulnerabilidades	Analizan una red o sistema para identificar puertos abiertos. También para escanear vulnerabilidades conocidas y explorar máquinas virtuales, BYOD y BBDD de clientes (e.g., Nipper, Core Impact, Nessus, SAINT y OpenVAS)

10

Herramientas de los Agentes de Amenazas

Tipo de Ataque	Descripción
Intercepción pasiva (eavesdropping)	Hacker captura y "escucha" tráfico de red. También se conoce como sniffing o snooping
Modificación de datos	Si los hackers han obtenido tráfico de la empresa, pueden alterar datos en el paquete sin el conocimiento del remitente o receptor
Suplantación de dirección IP	Atacante crea un paquete IP que parece provenir de una dirección válida dentro de la Intranet corporativa
Basados en contraseñas	Hackers descubren una cuenta válida de usuario y tienen mismos derechos que el usuario real. Pueden usar la cuenta válida para obtener listas de otros usuarios, información de red, cambios de servidor, configuraciones de red, modificar, redirigir o borrar datos
DoS	Impide el uso normal de una computadora o red. También puede saturar una computadora o toda la red con tráfico hasta que se apaguen por sobrecarga. También puede bloquear tráfico (i.e., eso deriva en la pérdida de acceso a recursos de red por parte de usuarios autorizados)
MITM	Hackers se colocan entre origen y destino para monitorear, capturar y controlar la comunicación de forma activa y transparente
Claves comprometidas	Puede utilizarse para obtener acceso a una comunicación asegurada sin que el emisor ni el receptor se enteren del ataque
Analizador de protocolos	Aplicación o dispositivo que puede leer, monitorear y capturar datos en la red. Si los paquetes no están cifrados, un analizador de protocolos permite ver por completo los datos que los componen

Malware

- Los terminales son especialmente propensos a ataques de malware.
- Los virus requieren acción humana para propagarse e infectar otros equipos a través de un archivo.
  - Ejemplo: cuando la víctima abre un adjunto de correo, abre un archivo de una unidad USB o descarga un archivo.
  - Se ocultan mediante su unión a un código informático, software o documentos del equipo.
    - Cuando se abre, el virus se ejecuta e infecta el equipo.
- Los virus pueden:
  - Modificar, dañar, eliminar archivos (e.g., HD completos)
  - Causar problemas de arranque del equipo o dañar aplicaciones.
  - Capturar y enviar información confidencial a los atacantes.
  - Acceder a cuentas de correo y utilizarlas para propagarse.
  - Permanecer inactivo hasta que el atacante lo requiera.

Malware

- Los virus modernos se desarrollan con intenciones muy específicas.

Tipos	Descripción
Virus en el sector de arranque	Ataca el sector de arranque, tabla de particiones de archivos o sistema de archivos
Virus de firmware	Ataca el firmware del dispositivo
Virus de macros	Utiliza la función de macros de MS Office con fines maliciosos
Virus del programa	Se introduce en otro programa ejecutable
Virus de script	Ataca al intérprete del SO que se utiliza para ejecutar los scripts

13

Malware

- Un troyano es un programa que parece útil pero también transporta código malicioso.
  - A menudo se proporcionan con programas gratuitos en línea (e.g., juegos de equipo).

Tipo de troyano	Descripción
Acceso remoto	Activa el acceso remoto no autorizado
Envío de datos	Proporciona al atacante datos confidenciales (e.g., contraseñas)
Destructivo	Daña o elimina archivos
Proxy	Usará el equipo de la víctima como dispositivo de origen para lanzar ataques y realizar otras actividades ilegales
FTP	Habilita servicios no autorizados de transferencia de archivos en dispositivos finales
Desactivador de software de seguridad	Detiene el funcionamiento de antivirus o cortafuegos
DoS	Retarda o detiene la actividad de red
Keylogger	Intenta activamente robar información confidencial (e.g., nº de tarjetas de crédito registrando pulsaciones de teclas efectuadas en un formulario web)

14

Malware

Malware	Descripción
Adware	Se suele distribuir en las descargas de software. Puede mostrar anuncios no solicitados mediante ventanas emergentes del navegador web, nuevas barras de herramientas o redireccionamientos inesperados a un sitio web diferente. Las ventanas emergentes pueden ser difíciles de controlar, ya que las modernas son más rápidas que la mano del usuario.
Ransomware	Generalmente cifra los archivos para que el usuario no pueda acceder a ellos y presenta un mensaje donde exige un rescate para suministrar la clave de descifrado. Los usuarios sin copias de respaldo deben pagar el rescate para descifrar sus archivos. El pago se hace mediante transferencia bancaria o divisas criptográficas.
Rootkit	Usados para obtener acceso al nivel de administrador de un PC. Son difíciles de detectar porque pueden alterar cortafuegos, antivirus, archivos del sistema y comandos del SO para ocultar su presencia. Pueden proveer una puerta trasera para acceder al equipo, cargar archivos e instalar nuevo software para utilizarlo en un ataque DDoS. Se deben utilizar herramientas especiales para eliminar los rootkits y a veces es necesario reinstalar el SO completo.
Spyware	Similar al adware, pero se utiliza para recopilar información sobre el usuario y enviarla sin su consentimiento a los atacantes. Puede ser una amenaza menor si recopila datos de navegación o mayor si recopila información personal y financiera.
Gusano	Se replica a sí mismo y se propaga automáticamente sin participación del usuario aprovechando vulnerabilidades de software legítimo. Utiliza la red para buscar otras víctimas con la misma vulnerabilidad. Su objetivo suele ser restar velocidad o interrumpir las operaciones de redes.

15

Ataques de Red Habituales

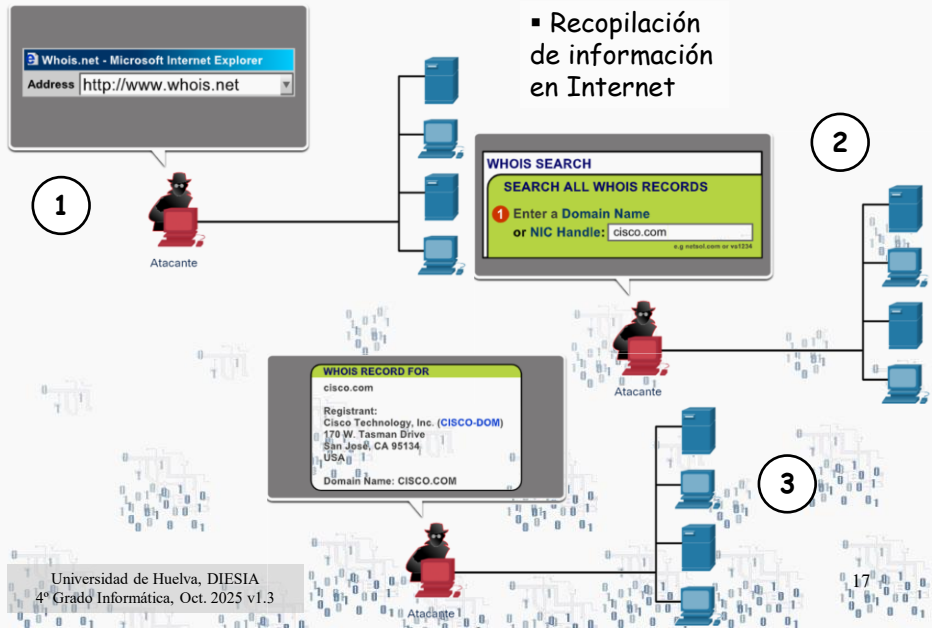
- Las redes son susceptibles a diferentes tipos de ataques.

1. Ataque de reconocimiento (i.e., recopilación de información):
   - Realizar detección y análisis no autorizado de sistemas, servicios o vulnerabilidades.
   - Precede al ataque de acceso o ataque DoS.

Técnica	Descripción
Recopilar información de un objetivo	El atacante está buscando información inicial sobre un objetivo. Herramientas: búsqueda de Google, páginas web de organizaciones, Whois
Iniciar un barrido de ping de la red objetivo	La recopilación de información generalmente revela la dirección de red del objetivo. El atacante ahora puede iniciar un barrido de ping para determinar qué direcciones IP están activas
Iniciar un análisis de puertos de las direcciones IP activas	Esto se utiliza para determinar qué puertos o servicios están disponibles. Herramientas: Nmap, SuperScan, Angry IP Scanner y NetScanTools
Ejecutar escáneres de vulnerabilidades	Útil para buscar puertos identificados para determinar tipo y versión de la aplicación y SO del host. Herramientas: Nipper, Core Impact, Nessus, SAINT y OpenVAS
Ejecutar herramientas de explotación de vulnerabilidades	El atacante ahora intenta descubrir servicios vulnerables que pueden ser explotados. Herramientas: Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit y Netsparker

16

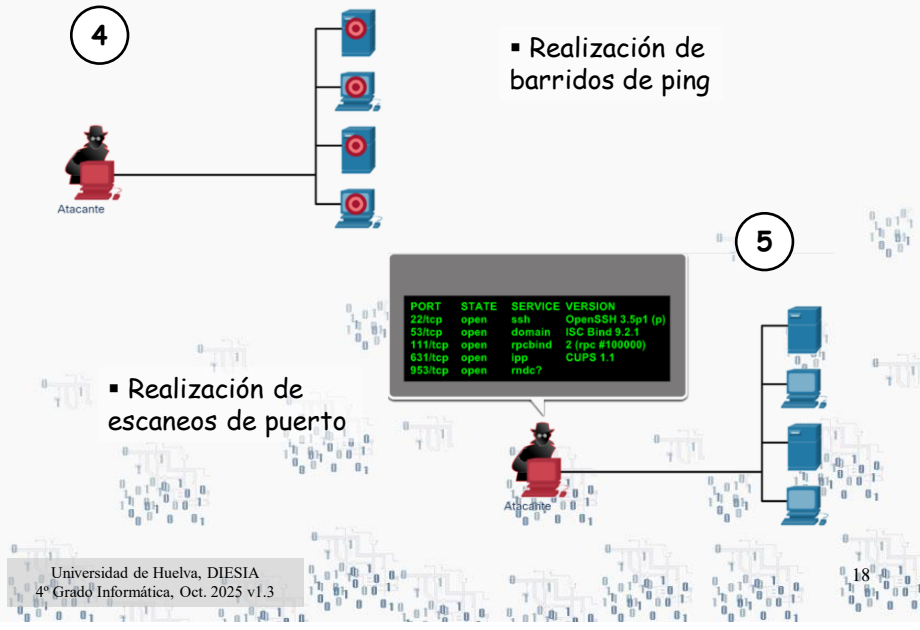
Ataques de Red Habituales



- Recopilación de información en Internet

17

Ataques de Red Habituales

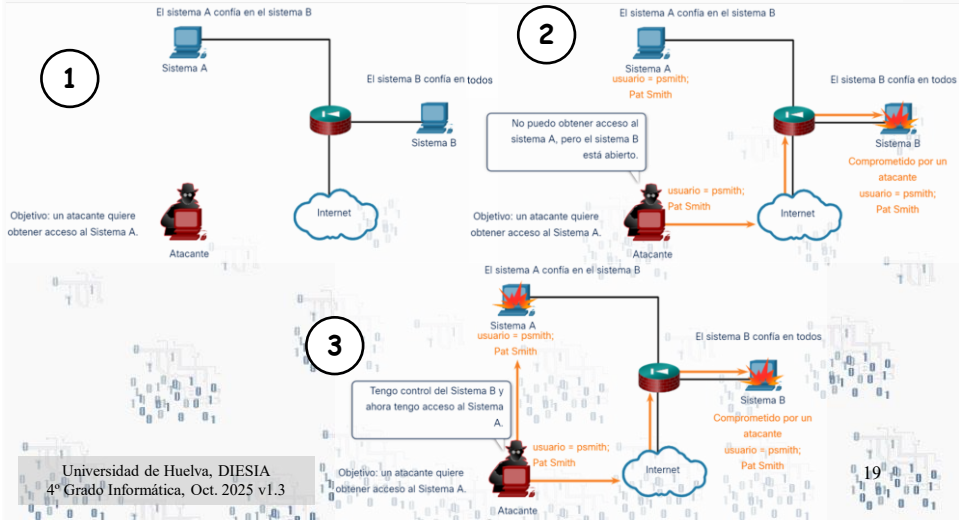


- Realización de barridos de ping
- Realización de escaneos de puerto

18

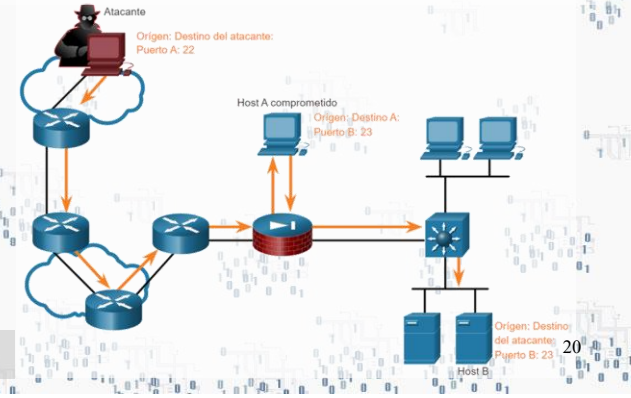
Ataques de Red Habituales

2. Ataque de explotación de confianza:
   - Un atacante utiliza privilegios no autorizados para acceder a un sistema, posiblemente comprometiendo el objetivo.



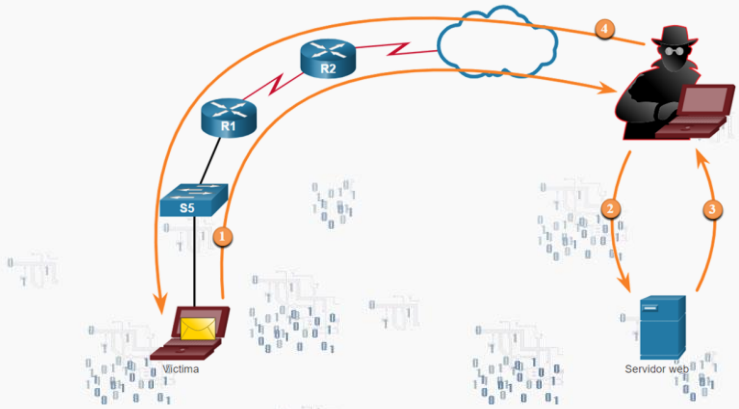
Ataques de Red Habituales

3) Ataque de redireccionamiento de puertos:
   - Se utiliza un sistema comprometido como base para atacar otros objetivos.
   - Ejemplo: un atacante usa SSH (puerto 22) para conectarse a un Host A comprometido.
   - El Host A es confiable para el Host B. El atacante puede usar Telnet (puerto 23) para acceder a él.



Ataques de Red Habituales

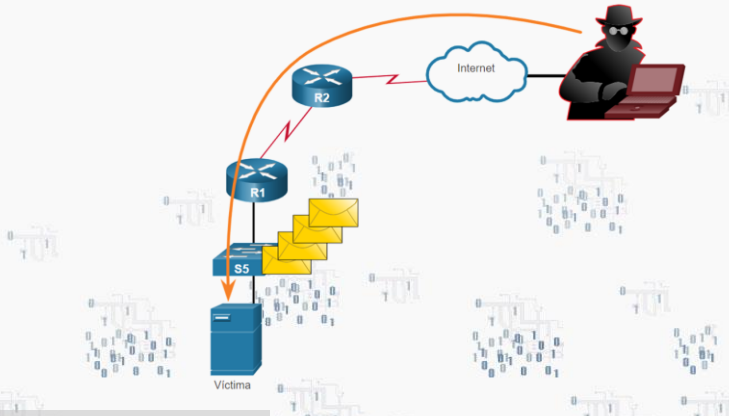
4. Ataque Man-in-the-Middle:
   - El atacante se coloca entre dos entidades legítimas para leer o modificar los datos que se transmiten entre ellos.



21

Ataques de Red Habituales

4. Ataque de desbordamiento de búfer:
   - El hacker ataca la memoria del búfer y la sobrecarga con valores inesperados.
   - Generalmente hace que el sistema no funcione (i.e., DoS).



22

Ataques de Red Habituales

5. Ataque de ingeniería social:
   - Intenta manipular personas para que realicen acciones o divulguen información confidencial.
   - Algunas técnicas son presenciales, mientras otras pueden ser por teléfono o Internet.
   - Los hackers confían en la predisposición que tienen las personas para ayudar.
   - También aprovechan las debilidades de los demás.
   - Ejemplo: hacker llama a un empleado autorizado por un problema urgente que requiere acceso inmediato a la red.
     - El hacker puede halagar al empleado, simular autoridad usando intimidación o apelar a la codicia del empleado.

Ataques de Red Habituales

Ataques de ingeniería social	Descripción
Pretexto	El atacante finge necesitar datos personales o financieros para confirmar la identidad del destinatario
Phishing	El atacante envía un mensaje fraudulento que parece ser de una fuente legítima y confiable para que la víctima instale malware en su dispositivo o revele información
Spear phishing	El atacante crea un ataque phishing dirigido específicamente a una persona u organización
Correo electrónico no deseado (correo basura)	Correo electrónico no solicitado que suele contener enlaces nocivos, malware o información engañosa
Algo por algo (quid pro quo)	El atacante solicita información personal a cambio de algo (e.g., obsequio)
Baiting (carnada)	El atacante deja deliberadamente una unidad de memoria (flash) infectada con malware en un sitio público. La víctima encuentra la unidad y sin darse cuenta instala malware
Suplantación de identidad (impersonation)	El atacante finge ser alguien más para ganarse la confianza de la víctima
Tailgating (infiltración)	El atacante sigue presencialmente a una persona autorizada para acceder a un área protegida
Shoulder surfing	El atacante sigue presencialmente una persona para robar contraseñas u otra información
Inspección de basura (dumpster diving)	El atacante hurga presencialmente en la basura en busca de documentos confidenciales

Ataques de Red Habituales

- Kit de herramientas de ingeniería social (SET):
  - Diseñado por TrustedSec para ayudar a crear ataques de ingeniería social para poner a prueba las propias redes.
  - Las empresas deben capacitar/educar a sus usuarios sobre riesgos de ingeniería social y desarrollar estrategias para validar identidades por teléfono, correo o en persona.
  - Código abierto (GitHub).





25

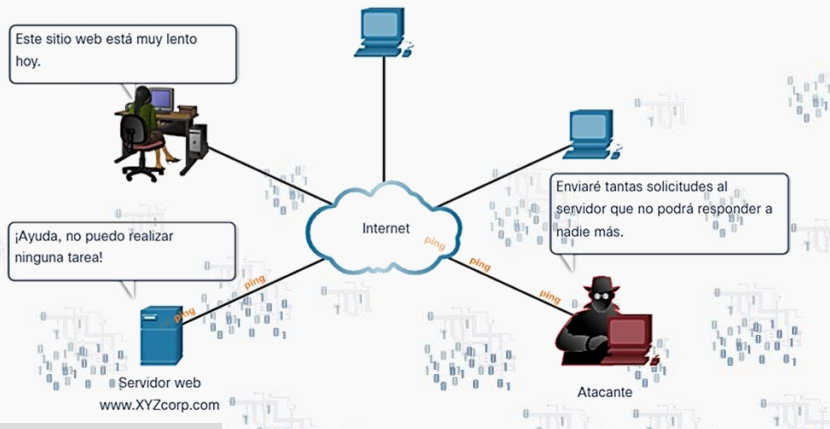
Ataques de Red Habituales

- DoS crea interrupción de los servicios de red para usuarios, dispositivos o aplicaciones:
  - Sobrecarga de tráfico:
    - El atacante envía una inmensa cantidad de datos a una velocidad que la red, el host o la aplicación no puede manejar
    - Hace que los tiempos de transmisión y respuesta aumenten.
  - Paquetes maliciosos formateados:
    - Se envía un paquete defectuoso a un host o aplicación que el receptor no puede manejar.
    - Hace que el dispositivo receptor se ejecute muy lentamente o se detenga.

26

Ataques de Red Habituales

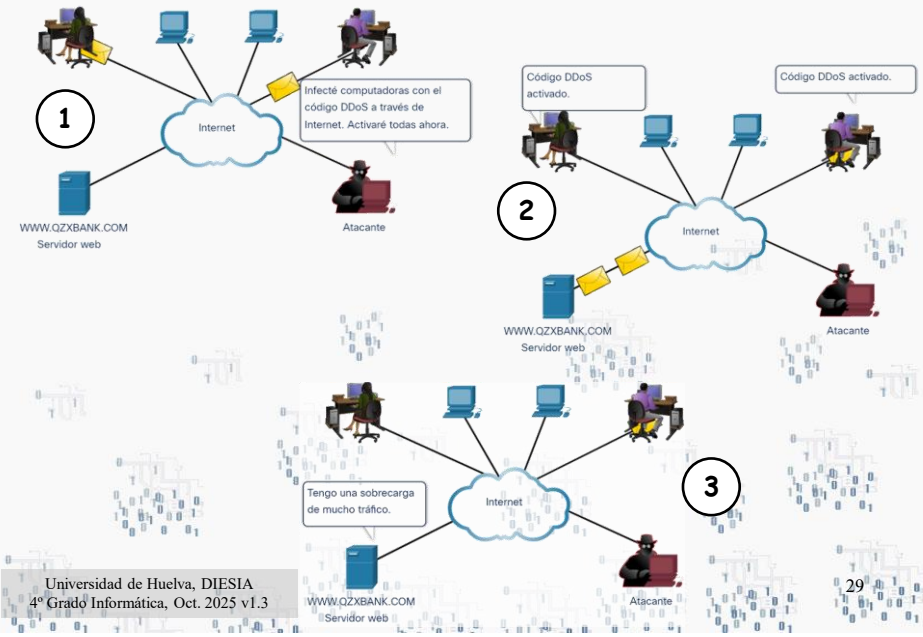
- Los ataques DoS son un riesgo importante porque interrumpen fácilmente la comunicación y causan pérdida de tiempo y dinero.
  - Son relativamente simples de ejecutar, incluso si lo hace un atacante inexperto.



Ataques de Red Habituales

- DDoS proviene de múltiples fuentes coordinadas:
  - Un hacker crea una red de hosts infectados (i.e., zombies).
  - El atacante utiliza un sistema CnC para enviar mensajes de control a zombies.
  - Los zombies escanean e infectan constantemente más hosts con malware de bot.
  - El malware de bot está diseñado para infectar un host, convirtiéndolo en zombie que puede comunicarse con el sistema CnC.
  - La colección de zombies se llama botnet.
  - Cuando está listo, el atacante proporciona instrucciones a los sistemas manipuladores para que los botnet de zombis lleven a cabo un ataque de DDoS.

Ataques de Red Habituales



Vulnerabilidades y Amenazas de IP

- El protocolo IP no hace ningún esfuerzo para validar si la dirección en el paquete proviene de ese origen:
  - Los atacantes pueden enviar paquetes con una dirección IP de origen falsa.
  - Pueden alterar los demás campos del encabezado IP para llevar a cabo sus ataques.

	Técnicas de ataque IP	Descripción
	ICMP	Los atacantes utilizan paquetes echo (pings) de ICMP para detectar subredes y hosts en una red protegida, y luego generar ataques DoS de saturación. También para modificar las tablas de enrutamiento de los hosts
	Amplificación y reflexión	Los atacantes envían solicitudes a un sistema e intentan redirigir las respuestas a usuarios legítimos con una dirección IP objetivo para impedir que tengan acceso a información o servicios (DDoS)
non blind →	Suplantación de direcciones	Los atacantes suplantan la dirección IP de origen en un paquete IP para realizar suplantación blind o non-blind (atacante puede no ver o ver las respuestas a los paquetes que envía)
non blind →	MITM	Los atacantes se posicionan entre origen y destino para monitorear, capturar y controlar la comunicación en forma transparente. Escuchan en silencio mediante la inspección de paquetes capturados o modifican paquetes y los reenvían a su destino original
blind →	Secuestros de sesiones	El atacante obtiene acceso a la red física y envía paquetes IP falsificados para secuestrar sesiones TCP (debe adivinar ciertos valores críticos como los números de secuencia TCP)

Vulnerabilidades y Amenazas de IP

- Los hackers utilizan ICMP para ataques de reconocimiento y análisis (recopilación de información):
  - Permite conocer la disposición de una topología de red.
  - Detectar qué hosts están activos.
  - Identificar el SO del host.
  - Determinar el estado de un firewall.
- Los hackers también usan ICMP para ataques DoS.
- Las redes deben tener filtros ACL estrictos en el perímetro de la red para evitar sondeos de ICMP desde Internet:
  - Los analistas de seguridad deben detectar estos ataques observando el tráfico capturado y los archivos de registro (e.g., firewalls e IDS) para generar alertas de seguridad.

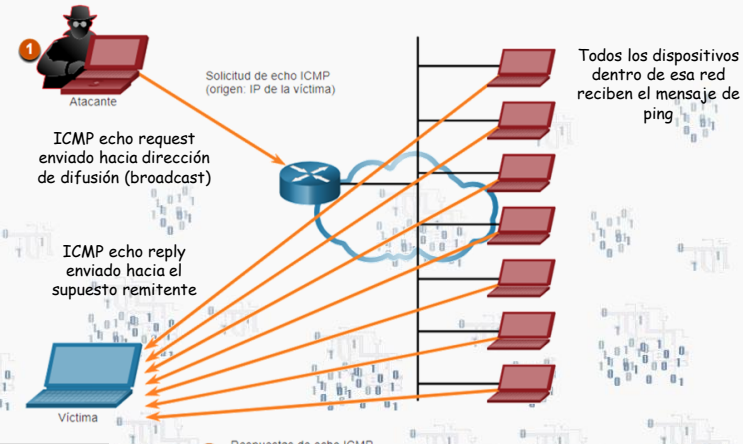
Vulnerabilidades y Amenazas de IP

- Mensajes comunes de ICMP de interés para atacantes:

Mensaje	Descripción
"Echo request" y "echo reply" de ICMP	Se utiliza para realizar la verificación del host y los ataques DoS
"Unreachable" de ICMP	Se utiliza para realizar ataques de reconocimiento y escaneo de la red. Consumen gran ancho de banda
"Address Mask reply" de ICMP	Se utiliza para determinar la máscara de subred en uso en una red IP interna
"Redirects" de ICMP	Se utiliza para lograr que un host envíe tráfico a través de una mejor ruta que comprende un dispositivo comprometido y crear un ataque MITM
"Router discovery" de ICMP	Se utiliza para inyectar entradas de rutas falsas sobre routers vecinos en la tabla de routing de un host objetivo

Vulnerabilidades y Amenazas de IP

- Los atacantes suelen usar técnicas de amplificación y reflexión para crear ataques de DDoS.
  - Ejemplo: "ataque Smurf" para abrumar un host objetivo.



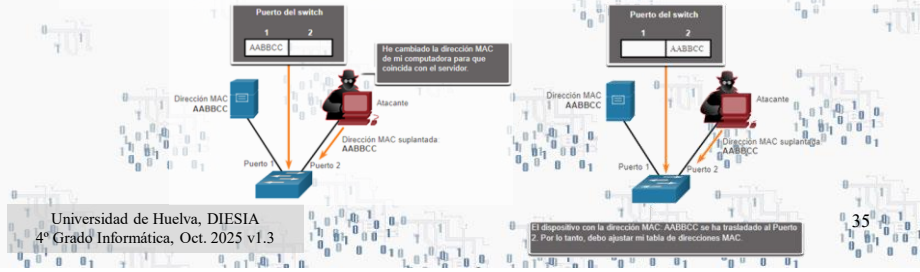
Vulnerabilidades y Amenazas de IP

- Los ataques de suplantación de dirección IP se producen cuando un atacante crea paquetes con dirección IP de origen falsa para ocultar la identidad o hacerse pasar por un usuario legítimo.
- Suele formar parte del ataque Smurf, pero también:
  - El atacante puede obtener acceso a datos que no podría obtener de otro modo.
  - También para pasar por alto configuraciones de seguridad.
- Los ataques de suplantación pueden ser no ciegos o ciegos:
  1. Non-blind spoofing: el atacante puede ver el tráfico que se envía entre host y destino. Usado para inspeccionar el paquete de respuesta de la víctima, determinar el estado de un cortafuegos o secuestrar una sesión autorizada.
  2. Blind spoofing: el atacante no puede ver el tráfico que se envía entre host y destino. Este tipo de suplantación se utiliza en ataques de DoS o predecir el número de secuencia TCP.

Vulnerabilidades y Amenazas de IP

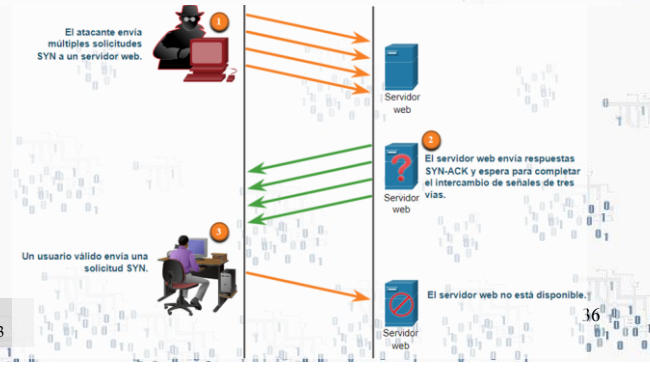
▪ Los ataques de suplantación de dirección MAC se utilizan cuando los hackers tienen acceso a la red interna.

- Los atacantes cambian la dirección MAC de su host para que coincida con otra dirección de un host conocido.
- El atacante envía una trama a través de la red con la dirección MAC configurada que es examinada por el switch al recibirla.
- El switch sobrescribe la entrada actual en la tabla CAM y asigna la dirección MAC al puerto nuevo.
- Luego reenvía las tramas destinadas hacia el host de destino al host atacante.



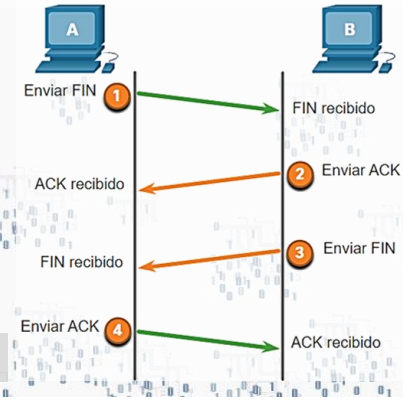
Vulnerabilidades y Amenazas de IP

- La inundación SYN de TCP ataca el saludo a 3 vías:
  - El atacante envía paquetes de solicitud de sesión SYN a un objetivo con una dirección IP de origen falsificada.
  - El dispositivo de destino responde con un paquete SYN-ACK a la dirección IP falsificada y espera un ACK.
  - Las respuestas nunca llegan, el destino se ve abrumado por las conexiones TCP abiertas y los servicios TCP se niegan a los usuarios legítimos.



Vulnerabilidades y Amenazas de IP

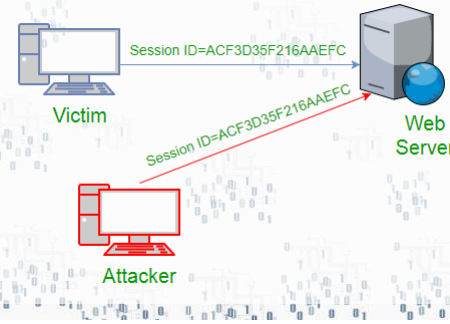
- TCP utiliza un intercambio de 4 vías para cerrar la conexión TCP con 2 segmentos FIN y ACK desde cada extremo.
- Una conexión TCP termina también de forma abrupta cuando recibe un bit RST:
  - Un ataque de restablecimiento TCP puede utilizarse para finalizar comunicaciones entre 2 hosts usando un paquete falso con un RST a uno o ambos extremos.



37

Vulnerabilidades y Amenazas de IP

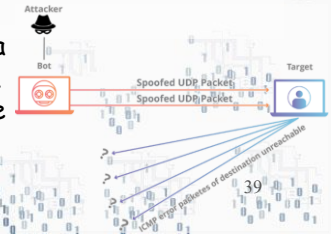
- Otra vulnerabilidad es el secuestro de sesiones de TCP.
  - Difícil de realizar, permite que un atacante tome el "control" de un host ya autenticado mientras se comunica con el destino.
  - El atacante tendría que suplantar la dirección IP de un host, predecir el siguiente número de secuencia y enviar un ACK al otro host.
  - Si tiene éxito, el atacante puede enviar datos y recibirlos dentro de la sesión.



38

Vulnerabilidades y Amenazas de IP

- Ataque de inundación UDP:
  - El atacante envía un gran número de datagramas a puertos aleatorios del sistema objetivo.
  - El servidor intenta procesar cada datagrama, consumiendo sus recursos (DoS).
  - Si se envían a puertos sin aplicaciones escuchando, el servidor responde con mensajes ICMP ("destino inalcanzable"), lo que aumenta aún más la carga.
  - Las herramientas (e.g., Unicorn o Low Orbit Ion Cannon) envían una avalancha de datagramas, a menudo desde un host falsificado, a un servidor en la subred.
  - Más fácil de llevar a cabo que TCP porque no establece una conexión antes de enviar datos.
  - Puede ser más difícil rastrear la fuente exacta del ataque y mitigarlo.
  - Pueden preceder a un ataque de amplificación y reflexión ICMP.

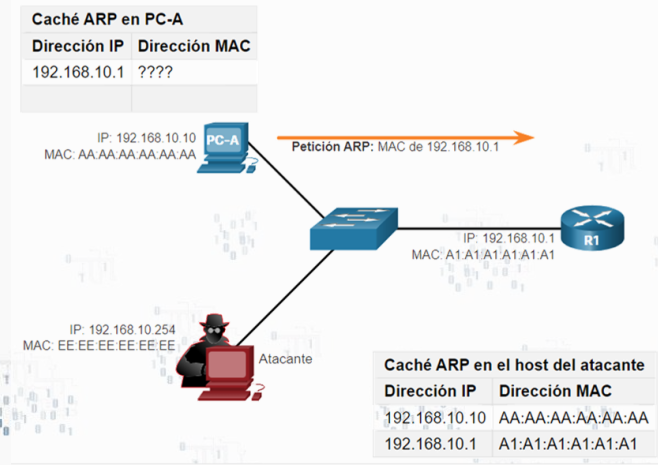


Vulnerabilidades y Amenazas de IP

- TCP / IP nunca se creó para la seguridad:
  - Los servicios que utilizan IP para direccionar funciones como ARP, DNS y DHCP tampoco son seguros.
- Cualquier cliente puede enviar una respuesta ARP no solicitada llamada "ARP gratuito":
  - Cuando un dispositivo se inicia por primera vez para informar a todos los demás sobre la nueva dirección MAC.
  - Los otros hosts en la subred almacenan en sus tablas la dirección MAC y la dirección IP que contiene dicho ARP.
- Esta característica de ARP significa que cualquier host puede reclamar ser el propietario de cualquier IP o MAC:
  - Un atacante puede envenenar la caché de ARP de los dispositivos en la subred y crear un ataque MITM para redireccionar tráfico.
  - Objetivo: atacar un host y cambiar su gateway predeterminado.
  - Herramientas: dsniff, Cain & Abel, ettercap y Yersinia

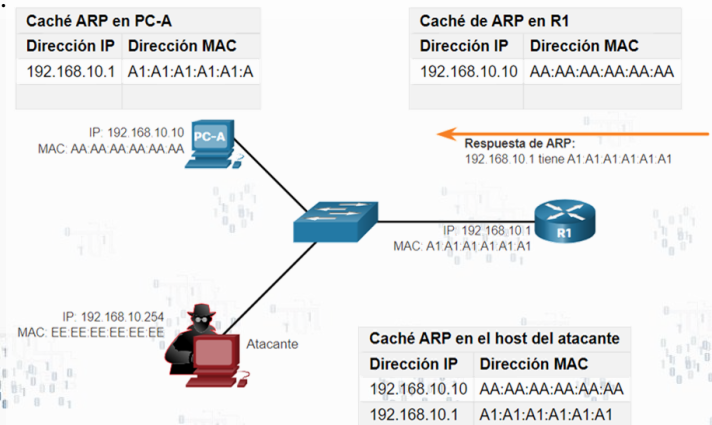
Vulnerabilidades y Amenazas de IP

- PC-A requiere la dirección MAC de su puerta de enlace (R1) y envía una solicitud ARP para la dirección 192.168.10.1



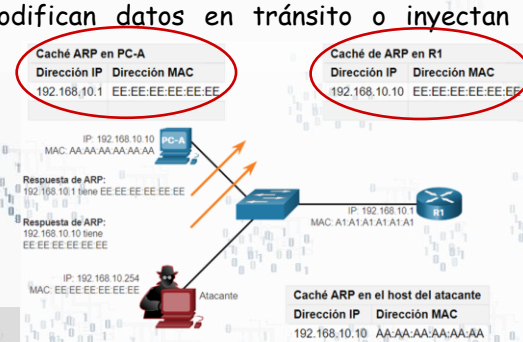
Vulnerabilidades y Amenazas de IP

- R1 actualiza su caché ARP con las direcciones IP y MAC de PC-A y envía una respuesta.
- PC-A actualiza su caché ARP con las direcciones IP y MAC de R1.



Vulnerabilidades y Amenazas de IP

- El atacante envía 2 respuestas ARP falsas usando su propia dirección MAC para las direcciones IP de destino indicadas.
- PC-A actualiza su caché ARP con su puerta de enlace, la cual ahora apunta hacia la MAC del atacante.
- R1 también actualiza su caché ARP con la dirección IP de PC-A y comienza a apuntar a la dirección MAC del atacante.
- El envenenamiento ARP puede ser:
  - Pasivo: los atacantes roban información confidencial.
  - Activo: modifican datos en tránsito o inyectan datos maliciosos.



Vulnerabilidades y Amenazas de IP

- La protección de DNS suele pasarse por alto.
- Los ataques a servidores DNS de resolución abierta explotan las consultas de clientes fuera de su dominio administrativo.

Vulnerabilidades de resolución DNS	Descripción
Ataque de envenenamiento de caché DNS	Los atacantes envían RR falsificados a un "DNS resolver" para redirigir usuarios de sitios legítimos a sitios maliciosos. Los ataques se pueden utilizar para informar a la resolución de DNS que utilice un servidor de nombre malicioso que proporciona información del RR para actividades maliciosas
Ataques de recursos disponibles de DNS	Un ataque DoS consume los servidores de resolución abierta de DNS. El ataque consume todos los recursos disponibles para afectar negativamente las operaciones de la resolución de DNS abierta. El impacto de este ataque puede requerir el reinicio de la resolución de DNS abierta o la interrupción y el reinicio de los servicios
Ataque de amplificación y reflexión de DNS	Los hackers usan ataque DoS o DDoS para aumentar el volumen de ataques y para ocultar la verdadera fuente de un ataque. Los atacantes envían mensajes de DNS a las resoluciones abiertas utilizando la dirección IP de un host de destino. Estos ataques son posibles porque la resolución abierta responde las consultas de cualquiera que pregunte

Vulnerabilidades y Amenazas de IP

- Para ocultar su identidad, los hackers utilizan ataques sigilosos de DNS.

Técnicas sigilosas de DNS	Descripción
Flujo rápido (fast flux)	Utilizado por los atacantes para ocultar la ubicación de sus servidores maliciosos como los que alojan sitios de phishing, malware o servidores CnC. Esta técnica aprovecha la capacidad del DNS para actualizar rápidamente las direcciones IP asociadas a un nombre de dominio, haciendo que el tráfico se redirija constantemente a diferentes servidores o redes de botnets que hacen de proxy, redirigiendo el tráfico a los servidores maliciosos reales.
Flujo IP doble	Variante que no solo actualiza rápidamente las direcciones IP asociadas a un dominio, sino que también actualiza las direcciones IP de los servidores DNS responsables de resolver esos dominios. Esto aumenta la dificultad para identificar el origen del ataque.
Algoritmos de generación de dominio	Los atacantes utilizan esta técnica para generar aleatoriamente nombres de dominio que puedan utilizarse como puntos de encuentro de sus servidores de CnC.

45

Vulnerabilidades y Amenazas de IP

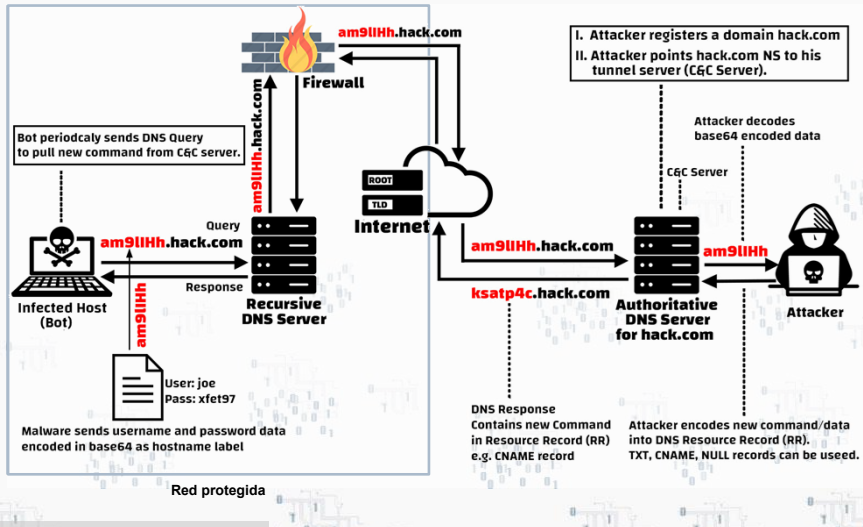
- El ataque de sombreado de dominio implica que el atacante tenga credenciales para crear múltiples subdominios para usar durante los ataques (e.g., malicioso.dominio-legitimo.com):
  - Los subdominios apuntan a servidores maliciosos sin alertar al propietario real del dominio principal.
- Los atacantes utilizan la tunelización de DNS para colocar tráfico no DNS en tráfico DNS:
  - Cuando un atacante desea comunicarse con bots dentro de una red protegida o extraer datos de la organización (e.g., BBDD de contraseñas).
  - Para detener el ataque, el administrador debe usar un filtro que inspeccione el tráfico DNS (e.g., consultas de DNS más largas de lo normal o que tienen un nombre de dominio sospechoso).
  - Las soluciones de DNS (e.g., Cisco OpenDNS) bloquean gran parte del tráfico de tunelización de DNS identificando dominios sospechosos.

46

Vulnerabilidades y Amenazas de IP

- Ejemplo: túnel DNS para instrucción CnC enviada a una botnet.
  1. Los datos se dividen en varias partes codificadas.
  2. Cada parte se coloca en una consulta de DNS de nivel inferior.
  3. Dado que no hay ninguna respuesta del DNS local para la consulta, la solicitud se reenvía a los servidores DNS recursivos del ISP.
  4. El DNS recursivo reenvía la consulta al servidor de nombres autorizado del atacante.
  5. El proceso se repite hasta que se envían todas las consultas que contienen las partes.
  6. Cuando el DNS del atacante recibe las consultas del dispositivo infectado, envía las respuestas para cada consulta DNS con las instrucciones CnC encapsuladas y codificadas.
  7. El malware en el host atacado vuelve a combinar las partes y ejecuta los comandos ocultos dentro.

Vulnerabilidades y Amenazas de IP

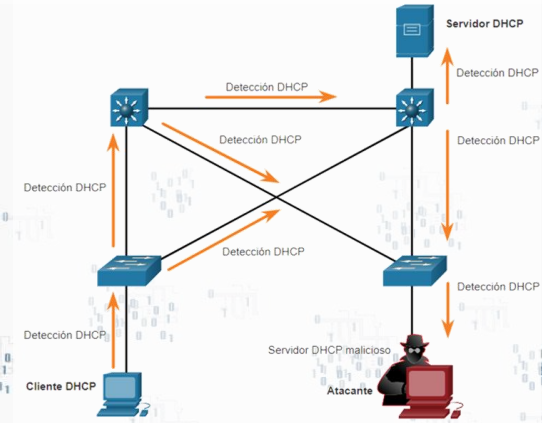


Vulnerabilidades y Amenazas de IP

- Un ataque de suplantación de DHCP se produce cuando un servidor DHCP dudoso brinda parámetros de configuración IP falsos a clientes legítimos:
  - Gateway predeterminado incorrecto:
    - El atacante proporciona un gateway no válido o dirección IP de su host para crear un ataque de MITM.
  - Servidor DNS incorrecto:
    - El atacante proporciona una dirección del servidor DNS incorrecta que dirige al usuario a un sitio web malicioso.
  - Dirección IP incorrecta:
    - El atacante proporciona una dirección IP no válida, dirección IP de puerta de enlace predeterminada no válida o ambas.
    - Luego, el hacker crea un ataque de DoS en el cliente DHCP.

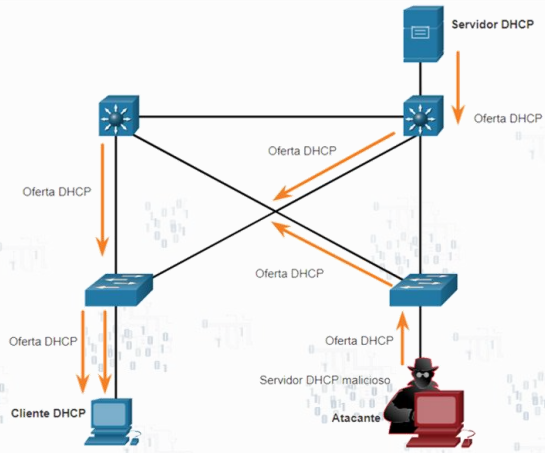
Vulnerabilidades y Amenazas de IP

- Un cliente legítimo requiere parámetros de configuración IP:
  - El cliente transmite una solicitud de DHCP Discover en busca de una respuesta de un servidor DHCP.
  - Ambos servidores recibirán el mensaje.



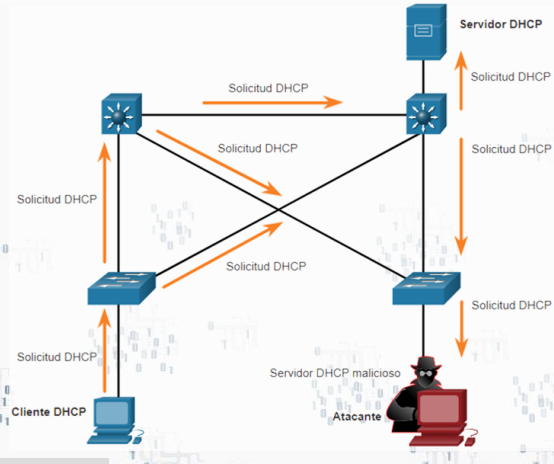
Vulnerabilidades y Amenazas de IP

- El servidor DHCP malicioso y el legítimo responden con parámetros de configuración IP válidos.
- El cliente responde a la primera oferta recibida.



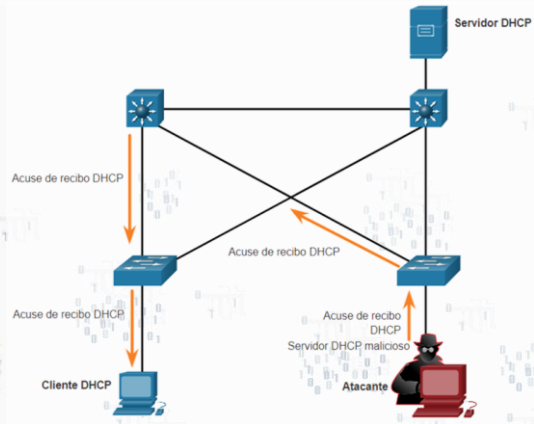
Vulnerabilidades y Amenazas de IP

- El cliente recibe primero la oferta del servidor malicioso y transmite una solicitud DHCP aceptando los parámetros.
- El servidor legítimo y el malicioso reciben la solicitud.



Vulnerabilidades y Amenazas de IP

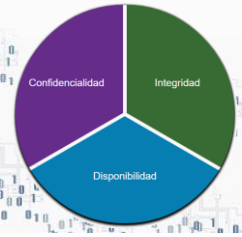
- Solo el servidor malicioso emite una respuesta unicast al cliente para acusar recibo de su solicitud.
- El servidor legítimo deja de comunicarse con el cliente porque la solicitud ya ha sido confirmada.



53

Mejores Prácticas en Seguridad de Redes

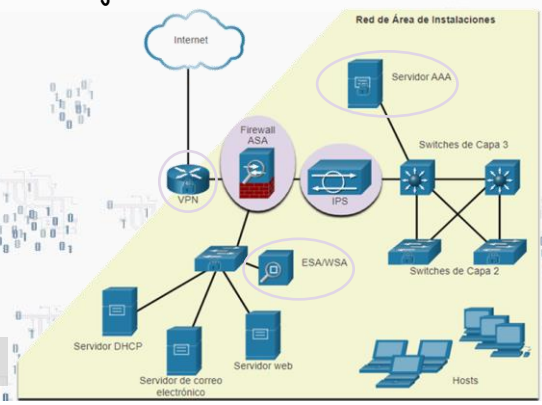
- La seguridad de la red consiste en proteger la información y los sistemas del acceso, uso, divulgación, interrupción, modificación o destrucción no autorizados.
- La mayoría de organizaciones siguen la tríada CID:
  - Confidencialidad. Solo individuos, entidades o procesos autorizados pueden tener acceso a información confidencial (e.g., algoritmos de cifrado).
  - Integridad. Proteger los datos de modificaciones no autorizadas (e.g., algoritmos de hashing criptográficos).
  - Disponibilidad. Los usuarios autorizados deben tener acceso ininterrumpido a los recursos y datos (e.g., implementar servicios redundantes, puertas de enlace y enlaces).



54

Mejores Prácticas en Seguridad de Redes

- Para garantizar comunicaciones seguras en redes públicas y privadas, el 1er objetivo es proteger los dispositivos (i.e., routers, switches, servidores y hosts).
- La mayoría de organizaciones emplean un enfoque de defensa en profundidad para la seguridad (enfoque en capas):
  - Requiere combinación de dispositivos y servicios de red que trabajen en conjunto.



55

Mejores Prácticas en Seguridad de Redes

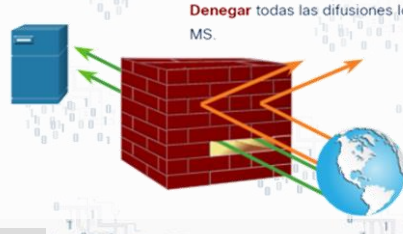
- VPN. Router con servicios VPN para sitios corporativos y acceso remoto de usuarios mediante túneles cifrados.
- ASA Firewall. Dispositivo dedicado que garantiza que el tráfico interno pueda salir y regresar, pero el tráfico externo no puede iniciar conexiones a hosts internos.
- IPS. Monitorea el tráfico entrante y saliente en busca de malware, firmas de ataques a redes y más. Si el sistema reconoce una amenaza, puede detenerla inmediatamente.
- ESA/WSA. Filtra spam, correos electrónicos sospechosos y sitios de malware en Internet conocidos y sospechosos.
- AAA Server. Servidor con BBDD segura de gente autorizada para acceder a dispositivos de red y administrarlos (los dispositivos autentican a los usuarios mediante esta BBDD).

56

Mejores Prácticas en Seguridad de Redes

- Un firewall es un sistema o grupo de sistemas que impone una política de control de acceso entre redes.

Permitir el tráfico de toda dirección externa al servidor web.	**Denegar** todo el tráfico entrante con direcciones de red que coincidan con las direcciones IP internas registradas.
Permitir el tráfico al servidor FTP.	**Denegar** todo el tráfico entrante al servidor proveniente de direcciones externas.
Permitir el tráfico al servidor SMTP.	**Denegar** todo el tráfico entrante de solicitudes de eco de ICMP.
Permitir el tráfico al servidor IMAP interno.	**Denegar** todas las consultas entrantes de MS Active Directory.
	Denegar todas las consultas de tráfico entrante al servidor MS SQL.
	Denegar todas las difusiones locales de dominios de MS.



57

Mejores Prácticas en Seguridad de Redes

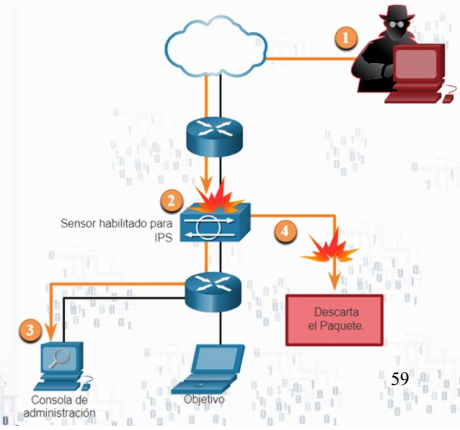
- Firewalls: único punto de tránsito entre las redes corporativas internas y externas (todo el tráfico circula por ellos).
- Aplican la política de control de acceso.
- Evitan la exposición de hosts, recursos y aplicaciones confidenciales a usuarios no confiables.
- Limpian el flujo de protocolos (i.e., evita el aprovechamiento de fallos en protocolos).
- Simplifican la administración de la seguridad (i.e., el control de acceso a redes se reduce a unos pocos firewalls).
- Un firewall mal configurado puede tener graves consecuencias para la red (e.g., convertirse en un punto único de fallo).
- Los datos de muchas aplicaciones no se pueden transmitir con seguridad mediante firewalls:
  - Los usuarios pueden buscar maneras de esquivar el firewall para recibir datos bloqueados (i.e., exponen la red a posibles ataques).
- El tráfico no autorizado se puede tunelizar u ocultar como tráfico legítimo a través del firewall.
- Pueden reducir la velocidad de la red.

58

Mejores Prácticas en Seguridad de Redes

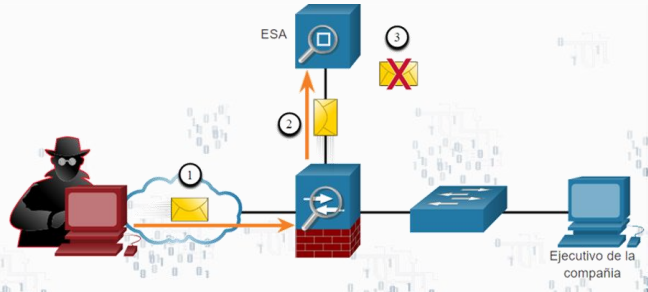
- La arquitectura de red puede integrar soluciones IDS / IPS (más escalables) en los puntos de entrada y salida de la red:
- Ambas tecnologías se implementan como sensores:
  - Un router configurado con software IPS.
  - Un dispositivo dedicado para proporcionar servicios.
  - Un módulo de red instalado en un ASA, switch o router.

1. El atacante envía un paquete destinado al objetivo.
2. El IPS intercepta el tráfico y lo evalúa contra amenazas conocidas (i.e., patrones atómicos o compuestos) y políticas configuradas.
3. El IPS envía un mensaje de registro a la consola de administración.
4. El IPS deja caer el paquete.



Mejores Prácticas en Seguridad de Redes

- ESA es un dispositivo especial diseñado para monitorear SMTP.
- Se actualiza constantemente mediante un sistema de monitoreo que utiliza una BBDD mundial en tiempo real (e.g., Cisco Talos) que detecta y correlaciona amenazas.
- ESA extrae datos de inteligencia cada 3-5 min.



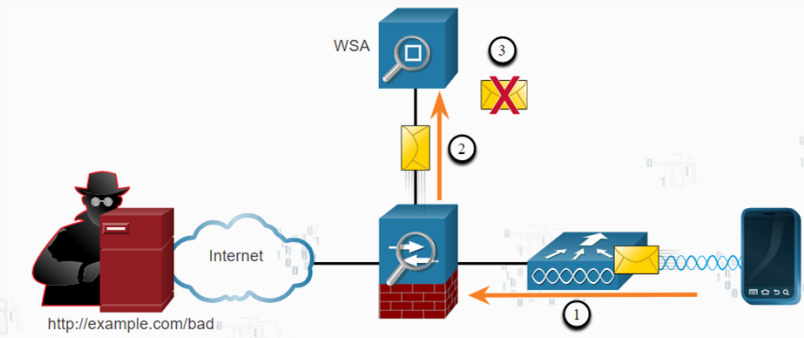
Mejores Prácticas en Seguridad de Redes

- WSA es una tecnología de mitigación para amenazas web (i.e., asegura y controla el tráfico web).
- Combina protección avanzada contra malware, visibilidad y control de aplicaciones, control de políticas de uso aceptable e informes.
- Proporciona un control completo sobre cómo los usuarios acceden a Internet:
  - Ciertas funciones y aplicaciones (e.g., chat, mensajería, vídeo y audio) pueden permitirse, restringirse con límites de tiempo y ancho de banda, o bloquearse de acuerdo con los requisitos de la organización.
  - Puede realizar listas negras de URL, filtrado URL, escaneo de malware, categorización de URL, filtrado de aplicaciones web, cifrado y descifrado del tráfico web.

61

Mejores Prácticas en Seguridad de Redes

- Ejemplo: usuario corporativo que intenta conectarse a un sitio conocido en la lista negra.



1. Un usuario intenta conectarse a un sitio web.
2. El firewall reenvía la solicitud del sitio web a la WSA.
3. La WSA evalúa la URL y determina que es un sitio conocido en la lista negra. El WSA descarta el paquete y envía un mensaje de acceso denegado al usuario.

62

Criptografía

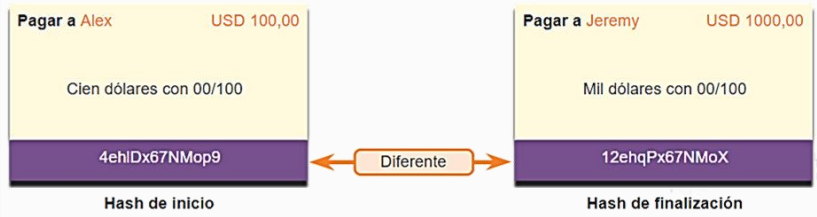
- Las organizaciones deben proporcionar soporte para proteger los datos a medida que viajan a través de enlaces:
  - Puede incluir tráfico interno, pero la mayor preocupación es proteger los datos que viajan fuera de la organización a sitios de sucursales, teletrabajadores y socios.
- Existen 4 elementos de las comunicaciones seguras:

1) Integridad de los Datos. Garantiza que el mensaje no se haya modificado mediante algoritmos de generación de hash (e.g., MD5 o SHA).
2) Autenticación de origen. Garantiza que el mensaje no sea falso y que remitente sea verdadero mediante autenticación con protocolos (e.g., HMAC).
3) Confidencialidad de los datos. Garantiza que solamente los usuarios autorizados puedan leer el mensaje mediante cifrado simétrico y asimétrico.
4) Imposibilidad de negación de los datos. Garantiza que el remitente no pueda refutar la validez de un mensaje enviado:
   - Solo el remitente tiene una firma única relacionada con el tratamiento del mensaje.

63

Criptografía

- Funcionamiento de hash:



El algoritmo hash funciona de la siguiente manera:

1. El dispositivo de envío ingresa el mensaje en un algoritmo hash y calcula su hash de longitud fija de **4ehiDx67NMop9**.
2. Luego, este hash se adjunta al mensaje y se envía al receptor. El mensaje y el hash se transmiten en texto sin formato.
3. El dispositivo receptor elimina el hash del mensaje e introduce el mensaje en el mismo algoritmo de hash. Si el hash calculado es igual al que se adjunta al mensaje, significa que el mensaje no se modificó durante su recorrido. Si los hash son no iguales, como se ve en la figura, ya no es posible garantizar la integridad del mensaje.

64

Criptografía

- Existen 3 funciones hash muy conocidas:

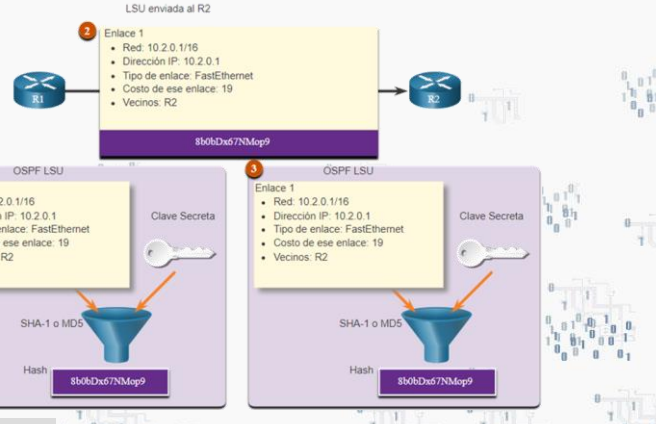
1. MD5 con síntesis de 128 bits:
   - Función unidireccional que produce un mensaje (hash) de 128 bits.
   - Algoritmo obsoleto que solo debe usarse cuando no hay mejores alternativas disponibles (usar SHA-2 en su lugar).
2. Algoritmo SHA:
   - Muy similar a las funciones MD5 con numerosas versiones. SHA-1 crea un mensaje hash de 160 bits y es un poco más lento que MD5.
   - SHA-1 tiene defectos conocidos y es obsoleto.
3. SHA-2 (incluye 224, 256, 384 y 512 bits, más modernos).

- Hash no brinda protección contra cambios deliberados (i.e., cualquier persona puede calcular un hash para los datos, siempre y cuando tengan la función hash correcta).
- Hash es vulnerable a ataques MITM y no proporciona seguridad a los datos transmitidos.

65

Criptografía

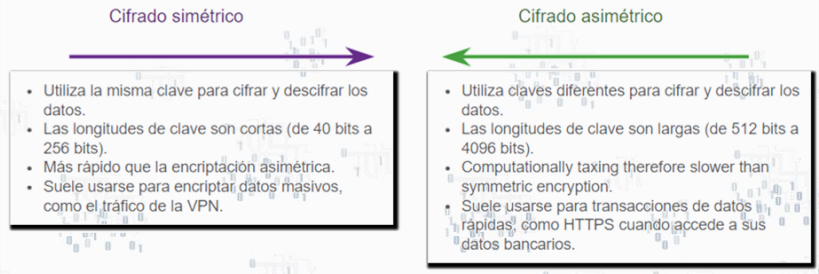
- Para agregar autenticación e integridad, se usa HMAC:
  - Utiliza una clave secreta como entrada a la función hash.
  - Solo emisor y receptor conocen la clave secreta y el resultado de la función de hash depende de datos y clave.



66

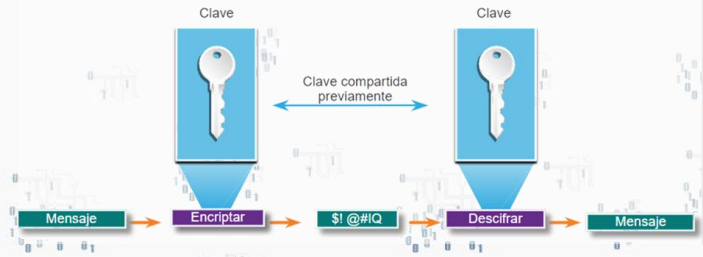
Criptografía

- Hay dos clases de encriptación utilizadas para brindar confidencialidad de los datos:
  - Los algoritmos de cifrado simétrico como DES, 3DES y AES se basan en la premisa de que cada parte que se comunica conoce la clave precompartida.
  - La confidencialidad de los datos también se puede garantizar utilizando algoritmos asimétricos, incluidos RSA y PKI.



Criptografía

- Los algoritmos simétricos utilizan la misma clave precompartida para encriptar y desencriptar datos.
- Suelen utilizarse con tráfico VPN:
  - Utilizan menos recursos de CPU que los algoritmos asimétricos.
- Cuanto más larga sea la clave, más tiempo en descubrirse.
- La mayoría de las claves tienen 112-256 bits:
  - Para garantizar que sea segura, se recomienda 128 bits.



Criptografía

Tipos	Descripción
DES	Obsoleto. Puede utilizarse en cifrado de flujo, pero suele funcionar en cifrado por bloques de 64 bits. Un cifrado de flujo encripta un byte o un bit a la vez.
3DES	Versión más reciente de DES, pero repite el proceso tres veces. Se considera muy confiable cuando se implementa con claves cortas.
AES	Algoritmo seguro y más eficiente que 3DES, popular y recomendado. Ofrece 9 combinaciones de longitud de clave y bloque (utiliza longitud de clave variable de 128, 192 o 256 bits para encriptar bloques de datos de 128, 192 o 256 bits de largo).
SEAL	Rápido y alternativo para DES, 3DES y AES. Usa una llave de cifrado de 160 bits y tiene menor impacto en la CPU en comparación con otros algoritmos basados en software.
RC para flujos	Desarrollado por Ron Rivest con numerosas variantes, pero RC4 es la de uso más frecuente. RC4 es un cifrado de flujo y se utiliza para proteger el tráfico web de SSL y TLS.

69

Criptografía

- Los algoritmos asimétricos están diseñados para que la clave de cifrado y descifrado sean diferentes:
  - Utilizan una clave pública y una privada:
    - Pueden utilizar longitudes entre 512 y 4.096 bits.
  - Ambas claves son capaces de encriptar, pero se requiere la clave complementaria para desencriptar.
  - El proceso también es reversible:
    - Los datos encriptados con la clave privada requieren la clave pública para desencriptarse.
  - Logran confidencialidad, autenticación e integridad.



70

Criptografía

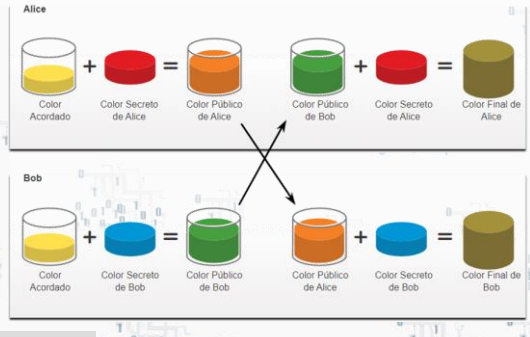
- Ejemplos de protocolos que utilizan algoritmos asimétricos:
  - IKE es un componente fundamental de las VPN con IPsec.
  - SSL se implementa como seguridad de la capa de transporte estándar de IETF (i.e., TLS).
  - SSH proporciona conexión segura de acceso remoto a dispositivos de red.
  - PGP es un programa de computadora que proporciona privacidad y autenticación criptográfica.
    - A menudo, se utiliza para aumentar la seguridad de las comunicaciones por correo electrónico.
- Los algoritmos asimétricos son sustancialmente más lentos que los simétricos:
  - Se basan en problemas matemáticos como la factorización o cálculo de logaritmos discretos de números grandes.
- Dado que carecen de velocidad, se utilizan en cifrados de poco volumen (e.g., firmas digitales e intercambio de claves).
- Sin embargo, la administración de claves es más fácil porque es posible hacer pública una de las dos claves.

Criptografía

Tipos	Longitud	Descripción
DH	512, 1024, 2048, 3072, 4096	Permite que 2 partes acuerden una clave que pueden utilizar para cifrar mensajes. Su seguridad depende de la suposición de que resulta sencillo elevar un número a una determinada potencia, pero difícil calcular qué potencia se utilizó sabiendo el número y el resultado.
DSS y DSA	512 - 1024	DSS especifica DSA como algoritmo para firmas digitales. DSA es un algoritmo de clave pública basado en ElGamal. La velocidad de creación es similar a RSA, pero 10 a 40 veces más lento para la verificación.
RSA	Entre 512 y 2048	Usado para cifrado de clave pública basado en la dificultad actual de factorizar números grandes. Es el primer algoritmo apto tanto para firmas como cifrados. Es ampliamente utilizado en protocolos de comercio electrónico y se considera seguro si se utilizan claves suficientemente largas e implementaciones actualizadas.
EIGamal	512 - 1024	Algoritmo de cifrado de claves asimétrico basado en el acuerdo de claves DH. Una desventaja del sistema ElGamal es que el mensaje cifrado se vuelve muy grande (aprox. el doble del tamaño del mensaje original y, por este motivo, solo se utiliza con mensajes pequeños como claves secretas).
Técnicas de curvas elípticas	160	Se puede utilizar para adaptar muchos algoritmos criptográficos como DH o ElGamal. La principal ventaja es que las claves pueden ser mucho más pequeñas.

Criptografía

- DH es un algoritmo asimétrico que permite que 2 partes generen una clave secreta idéntica compartida sin antes haberse comunicado.
- Ejemplos:
  - Intercambio de datos mediante una VPN con IPsec
  - Cifrado de datos en Internet usando SSL o TLS
  - Intercambio de datos con SSH.



Resumen

- Los ataques pueden interrumpir el comercio electrónico, causar pérdida de datos comerciales, amenazar la privacidad de las personas y comprometer la integridad de la información.
- Se requieren técnicas de mitigación antes, durante y después de un ataque.
- Hay piratas informáticos de "sombrero blanco", "sombrero gris" y "sombrero negro".
- Los activistas tienden a confiar en herramientas básicas y de libre acceso. Los piratas informáticos patrocinados por el estado crean códigos de ataque avanzados y personalizados.
- El hacker ético involucra a muchos tipos diferentes de herramientas para probar y mantener la seguridad de la red y sus datos.
- Los tipos comunes de ataques son espionaje, modificación de datos, suplantación de direcciones IP, basado en contraseña, DoS, MITM, clave comprometida y sniffer.
- Los tipos de malware comunes son virus, gusanos y troyanos, adware, ransomware, rootkit y spyware.

Resumen

- La mayoría de organizaciones siguen la tríada CID de seguridad: confidencialidad, integridad y disponibilidad.
- La defensa en profundidad incluye firewalls, IDS / IPS, ESA y WSA.
- Los 4 elementos de las comunicaciones seguras son integridad de datos, autenticación de origen, confidencialidad de datos y no repudio de datos.
- Las funciones hash garantizan que los datos no hayan cambiado (e.g., MD5, SHA y SHA-2). Para agregar autenticación al control de integridad se usa HMAC.
- Los algoritmos de cifrado simétrico utilizan DES, 3DES, AES, SEAL y RC donde cada parte conoce la clave precompartida.
- Los algoritmos de cifrado asimétrico incluyen RSA y PKI.
- DH es un algoritmo matemático asimétrico que permite que 2 partes generen una clave secreta idéntica compartida sin antes haberse comunicado.

Glosario de Términos

- 3DES. Triple DES
- AAA. Authentication, authorization y accounting
- ACL. Lista de Control de Acceso
- AES. Estándar de Cifrado Avanzado
- ASA. Adaptive Security Appliance
- BBDD. Bases de Datos
- CID. Confidencialidad, Integridad y Disponibilidad
- CnC. Comando y Control
- DDoS. Distributed DoS
- DES. Data Encryption Standard
- DH. Diffie-Hellman
- DoD. Denial of Service
- DSA. Digital Signature Algorithm
- DSS. Digital Signature Standard
- ESA. Email Security Appliance
- HD. Hard Disc
- HMAC. Hash Message Authentication Code

Glosario de Términos

- ICMP. Protocolo de Mensajes de Control de Internet
- IDS. Sistemas de Detección de Intrusiones
- IETF. Internet Engineering Task Force
- IKE. Internet Key Exchange
- IPS. Sistema de Prevención de Intrusiones
- MD5. Message Digest versión 5
- MITM. Man in the Middle
- PGP. Pretty Good Privacy
- PKI. Infraestructura de Clave Pública
- RC. Rivest ciphers
- RR. Registros de Recursos
- RSA. Rivest, Shamir y Adleman
- SEAL. Algoritmo de Cifrado Optimizado por Software
- SET. Social Engineering Toolkit
- SHA. Secure Hash
- SMTP. Protocolo Simple de Transferencia de Correo
- SSH. Secure Shell

77

Glosario de Términos

- SSL. Secure Socket Layer
- TLS. Transport Layer Security
- WSA. Web Security Appliance

78

Bibliografía

[1] CCNAv7. Enterprise Networking, Security, and Automation Companion Guide. Cisco Press, 2020.
[2] CCNA4 Versión 3.1. *Tecnologías WAN*. CISCO Networking Academy Program.
[3] CCNA Routing & Switching, Connecting Networks

